

Actividad 1: Análisis y planificación del pentest

Hacker Women Council – Ethical Hacking

Katerin Carolina Prieto Goita

Caso Aurora Market: Plan de Pentest

1- Objetivo del Pentest

Evaluación del nivel de seguridad de la aplicación web de Aurora Market para la identificación de vulnerabilidades explotables y brindar recomendaciones para la protección de sus clientes.

1. Confirmar si el incidente reportado corresponde a una vulnerabilidad real y explotable, identificando su causa técnica.
2. Identificar fallas de seguridad en los mecanismos de autenticación, control de acceso, validación de los datos y lógica del negocio de la plataforma.
3. Documentar y priorizar los hallazgos según su nivel de riesgo, entregando recomendaciones claras de remediación para el equipo de desarrollo de Aurora Market para poder corregirlas.

2- Alcance

- Si se evaluara:
 - Aplicación Web de Aurora Market (Identificado registro, login, catálogo, carrito, checkout, historial de pedidos).
 - Panel administrativo del personal.
 - Mecanismos de autenticación de la plataforma web.
- Fuera del alcance:
 - Redes sociales de Aurora Market.
 - Equipos personales de empleados.
 - Cuentas de correo corporativo.
 - Proveedores externos.
 - Cualquier sistema no explícitamente autorizado por Aurora Market.

3- Autorización y Condiciones

- Permisos requeridos:
 - Autorización para acceso a la Aplicación Web de Aurora Market (sobre registro, login, catálogo, carrito, checkout, historial de pedidos).
 - Permisos para usar cuentas de prueba (modo cliente y modo administrativo).
 - Autorización formal por escrito que respalde la legitimidad de la actividad.
 - Acuerdo de confidencialidad que autorice el manejo temporal de cualquier información sensible.

- Condiciones acordadas:
 - Alcance delimitado, no se permite atacar redes sociales, equipos personales de empleados, cuentas de correo, proveedores externos ni otros sistemas fuera de lo acordado.
 - No interrupción del servicio, prohibido modificar, eliminar o exponer información real de clientes.
 - Horarios definidos, realización de pruebas en horarios de menor actividad para minimizar el impacto en las operaciones.
 - Canales de comunicación y contactos de emergencia.

4- Tipo de Pentest: Gray-Box

Desarrollado por la información suministrada al caso, se puede identificar que el equipo no cuenta con los accesos al código fuente ni a la configuración interna de la infraestructura de Aurora Market, pero en este caso si se tiene identificado que existe una aplicación web, una base de datos, mecanismos de autenticación y diferentes tipos de usuarios (clientes y personal administrativo). Identificando que se tiene un conocimiento parcial del cliente.

Adicionalmente el enfoque de caja gris simula de forma realista el escenario del incidente reportado donde un usuario autenticado termino viendo información que no le correspondía, realizar evaluación de las credenciales permite reproducir ese mismo escenario.

5- Planificación

- Objetivo: El equipo deberá revisar y alinearse sobre que busca lograr el pentest por parte del cliente, asegurando que todos entiendan la prioridad.
- Alcance: El equipo confirmara internamente que está permitido y que quedaría estrictamente prohibido, para evitar errores durante la actividad.
- Permisos y condiciones: El equipo debe verificar que se cuenta con la autorización formal firmada, el acuerdo de confidencialidad y las reglas acordadas antes de tocar cualquier sistema. Nadie debe iniciar pruebas sin esta confirmación.
- Metodología a utilizar: El equipo identifica que se trabajará bajo OWASP, y distribuye qué categorías del Top 10 revisará cada integrante.
- Recopilación de información previa: El equipo debe reunir toda la información a suministrada y repasar toda la información entregada por Aurora Market.
- Recursos necesarios: El equipo debe preparar y distribuir cuentas de prueba, entorno o ambiente de pruebas, identificar herramientas a utilizar.
- Programación del pentest: El equipo deberá armar un cronograma interno con fechas de inicio y fin, y coordinar los horarios de menor actividad acordados con el cliente, asignando quién ejecuta qué fase y cuándo.

6- Planificación

- Reconocimiento: En esta fase el equipo debería de conocer la aplicación realizando una navegación con usuario normal, identificando todas las paginas y funcionalidades de la aplicación para tener mapeado los distintos roles existentes y como se diferencia cada interfaz. También detectando las tecnologías usadas como los tipos de sesión, cookies, frameworks visibles, mensajes de error por defecto.
- Análisis de vulnerabilidades: En esta fase con el mapeo ya hecho, el equipo buscaría activamente posibles debilidades, sin explotarlas todavía a fondo como Revisar si el backend valida permisos en cada endpoint, o si solo el frontend oculta ciertas opciones, probar mecanismos de autenticación, probar la manipulación de parámetros sensibles como precios, cantidades, entre otros. Utilizando el uso de la herramienta Burp Suite para detectar configuraciones inseguras o exposición de datos.
- Explotación: En esta fase de manera controlada con las vulnerabilidades explotables encontradas en el análisis de la herramienta Burp Suite, se debería explotar de forma controlada usando una cuenta de prueba propia,

intentar acceder efectivamente a datos de otra cuenta de prueba para Confirmar fallas de inyección o manipulación de parámetros. Toda esta información debe ser registrada para evidenciar cada resultado de la explotación.

- Post-explotación: En esta fase se debe determinar si sería posible acceder a los datos de todos los clientes evaluando la escala del problema identificado, Verificar si desde una cuenta comprometida se podría llegar a funciones administrativas, Evaluar qué tipo de información quedaría expuesta y si existiría posibilidad de persistencia.
- Informe: En esta fase se debe redactar cada hallazgo con descripción del problema, pasos detallados para reproducirlo y evidencia. Donde incluya un resumen ejecutivo para la dirección de Aurora Market.

7- Investigación

Metodología Elegida: OWASP

¿Por qué sería útil para este proyecto?

Para este caso elegí OWASP porque el trabajo que nos pidió Aurora Market se limita únicamente a su aplicación web, y esa es justo la especialidad de esta metodología. A diferencia de PTES o de OSSTMM, que están pensadas para pentest más generales (redes, infraestructura, incluso ingeniería social), OWASP se enfoca de lleno en cómo evaluar aplicaciones web, que es exactamente lo que necesitamos aquí.

Además, hay algo que la hace especialmente relevante para este caso puntual: el incidente que reportó el cliente, donde vio información de otra cuenta, encaja casi perfecto con una de las categorías del OWASP Top 10 llamada "Broken Access Control" (control de acceso roto), que incluye este tipo de fallas conocidas como IDOR. Así que no es una elección al azar, sino que apunta directo al problema que motivó todo este pentest.

Otra ventaja es que OWASP no se queda solo en la teoría: su guía de pruebas (Testing Guide) explica paso a paso cómo revisar cosas como el login, el manejo de sesiones, el carrito de compras o el checkout, que son justo las funciones que tiene la plataforma de Aurora Market. Y por si fuera poco, es una metodología muy usada en el mundo real dentro del comercio electrónico, lo que le da más peso y seriedad al informe que finalmente se le entregue a la empresa.